



TEMA 7

INTRODUCCIÓN A TÉCNICAS DE RED TEAM. TTPS 5-14



Una introducción basada en MITRE ATT&CK
sobre TTPs de "ataque" (Post-Explotación)



"S-82 NARCISO MONTURIOL" PROJECT v5.0

Por favor, informa de problemas con los materiales a redondojose@uniovi.es



Departamento de Informática
Universidad de Oviedo



Universidad de Oviedo

Logo: @creative_vanesa (Instagram)



ÍNDICE



Introducción a técnicas de Post-Explotación



Bloque 1: Infiltrándose como Administrador



TA0003. Persistence



TA0004. Privilege Escalation



Bloque 2: Operando de forma encubierta



TA0005. Defense Evasion



TA0006. Credential Access



TA0007. Discovery



TA0008. Lateral Movement



TA0009. Collection



TA0011. Command and Control



TA0010. Exfiltration



TA0040. Impact

[< Ir al Índice](#)



INTRODUCCIÓN A TÉCNICAS POST-EXPLOTACIÓN

Usando el MITRE ATT&CK para saber qué hacen los adversarios una vez entran en nuestros sistemas



Departamento de Informática
Universidad de Oviedo



Universidad de Oviedo

¿QUÉ TE VAS A ENCONTRAR EN ESTE BLOQUE?

● En este bloque aprenderás

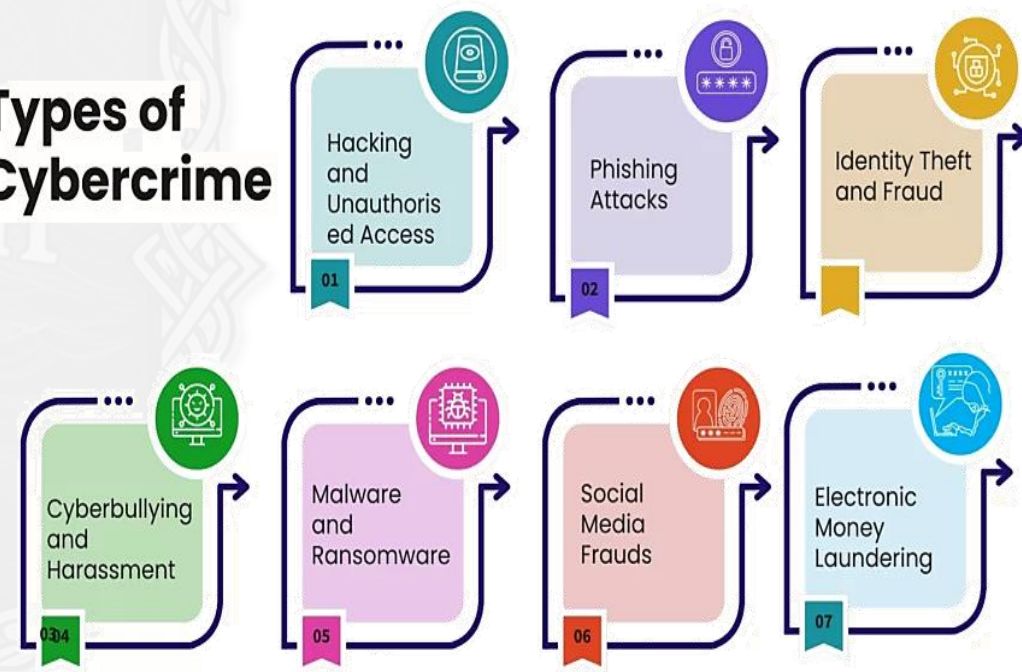
- Las distintas **fases de post-explotación** una vez has comprometido un sistema y ejecutado tu código en él
- El **uso de GTFOBins** para elevar tus privilegios de ejecución
- Cómo usar la técnica **GTFOBins** para **elevar** tus privilegios y **exfiltrar** información
- Las potenciales **consecuencias de una intrusión** en un sistema de acuerdo con el MITRE ATT&CK y su gravedad



¿QUÉ ES LA POST-EXPLOTACIÓN?

- Toda acción de un adversario tras obtener acceso inicial a un sistema o red
- Tiene varias tácticas (página siguiente)
 - Cada táctica tiene un propósito diferente
- Básicamente, es cualquier cosa que ocurra después de la 'entrada' para lograr los objetivos finales del ataque
 - Y puede haber múltiples objetivos diferentes (imagen)...

Types of Cybercrime



MITRE ATT&CK. TÉCNICAS Y TÁCTICAS DE POST-EXPLOTACIÓN



SSI

Execution	Persistence	Privilege Escalation	Defense Evasion	Credential Access	Discovery	Lateral Movement	Collection	Command and Control	Exfiltration	Impact
16 techniques	23 techniques	14 techniques	45 techniques	17 techniques	33 techniques	9 techniques	17 techniques	18 techniques	9 techniques	15 techniques
Command and Control	Account Manipulation (7)	Abuse Elevation Control Mechanism (6)	Abuse Elevation Control Mechanism (6)	Adversary-in-the-Middle (4)	Account Discovery (4)	Exploitation of Remote Services	Adversary-in-the-Middle (4)	Application Layer Protocol (5)	Automated Exfiltration (1)	Account Access Removal
Scripting Interpreter (12)	BITS Jobs	Access Token Manipulation (5)	Access Token Manipulation (5)	Brute Force (4)	Application Window Discovery	Internal Spearphishing	Archive Collected Data (3)	Communication Through Removable Media	Data Transfer Size Limits	Data Destruction (1)
Container Management	Boot or Logon Autostart Execution (14)	Account Manipulation (7)	BITS Jobs	Credentials from Password Stores (6)	Browser Information Discovery	Lateral Tool Transfer	Audio Capture	Content Injection	Exfiltration Over Alternative Protocol (3)	Data Encrypted for Impact
Deploy Container	Boot or Logon Initialization Scripts (5)	Boot or Logon Autostart Execution (14)	Build Image on Host	Exploitation for Credential Access	Cloud Infrastructure Discovery	Remote Service Session Hijacking (2)	Automated Collection	Data Encoding (2)	Exfiltration Over C2 Channel	Data Manipulation (3)
File Administration	Cloud Application Integration	Boot or Logon Initialization Scripts (5)	Debugger Evasion	Forced Authentication	Cloud Service Dashboard	Remote Services (8)	Browser Session Hijacking	Data Obfuscation (3)	Exfiltration Over Other Network Medium (1)	Defacement (2)
Initiation for Client	Compromise Host Software Binary	Create or Modify System Process (5)	Deobfuscate/Decode Files or Information	Forge Web Credentials (2)	Cloud Service Discovery	Replication Through Removable Media	Clipboard Data	Dynamic Resolution (3)	Exfiltration Over Physical Medium (1)	Disk Wipe (2)
Process Injection	Create Account (3)	Domain or Tenant Policy Modification (2)	Deploy Container	Input Capture (4)	Cloud Storage Object Discovery	Software Deployment Tools	Data from Cloud Storage	Encrypted Channel (2)	Exfiltration Over Web Service (4)	Email Bombing
Inter-Process Communication (3)	Create or Modify System Process (5)	Escape to Host	Direct Volume Access	Modify Authentication Process (9)	Container and Resource Discovery	Taint Shared Content	Data from Configuration Repository (2)	Fallback Channels	Exfiltration Over Web Service (4)	Endpoint Denial of Service (4)
Live API	Event Triggered Execution (17)	Exploitation for Privilege Escalation	Email Spoofing	Multi-Factor Authentication Interception	Debugger Evasion	Use Alternate Authentication Material (4)	Data from Information Repositories (5)	Hide Infrastructure	Scheduled Transfer	Financial Theft
Scheduled Task/Job (5)	Exclusive Control	Hijack Execution Flow (12)	Exploitation for Defense Evasion	Multi-Factor Authentication Request Generation	Device Driver Discovery		Data from Local System	Ingress Tool Transfer	Transfer Data to Cloud Account	Firmware Corruption
Serverless Execution	External Remote Services	Implant Internal Image	File and Directory Permissions Modification (2)	Network Sniffing	Domain Trust Discovery		Data from Network Shared Drive	Multi-Stage Channels		Inhibit System Recovery
Red Modules	Hijack Execution Flow (12)	Modify Authentication Process (9)	Hide Artifacts (14)	OS Credential Dumping (8)	File and Directory Discovery		Data from Removable Media	Non-Application Layer Protocol		Network Denial of Service (2)
Software Deployment	Implant Internal Image	Scheduled Task/Job (5)	Hijack Execution Flow (12)	Steal Application Access Token	Group Policy Discovery		Data Staged (2)	Non-Standard Port		Resource Hijacking (4)
System Services (3)	Modify Authentication Process (9)	Valid Accounts (4)	Impair Defenses (11)	Steal or Forge Authentication Certificates	Log Enumeration		Email Collection (3)	Protocol Tunneling		Service Stop
User Execution (4)	Modify Registry		Impersonation	Steal or Forge Kerberos Tickets (5)	Network Service Discovery		Input Capture (4)	Proxy (4)		System Shutdown/Reboot
Windows Management	Office Application Startup (6)		Indicator Removal (10)	Steal Web Session Cookie	Network Share Discovery		Screen Capture	Remote Access Tools (3)		
Automation	Power Settings		Indirect Command Execution		Network Sniffing		Video Capture	Traffic Signaling (2)		
	Pre-OS Boot (5)		Masquerading (11)		Password Policy Discovery			Web Service (3)		
			Modify Authentication Process (9)		Peripheral Device Discovery					
			Modify Cloud Compute Infrastructure (5)		Permission Groups Discovery (3)					
					Process Discovery					
					Query Registry					
					Remote System Discovery					

Fuente:
<https://attack.mitre.org/>

Tácticas relacionadas con la post-explotación

Fuente:
<https://attack.mitre.org/>

Tácticas relacionadas con la post-explotación

< Ir al Índice



BLOQUE 1: INFILTRÁNDOSE COMO ADMINISTRADOR

¡Yo soy (g)root!



Departamento de Informática
Universidad de Oviedo

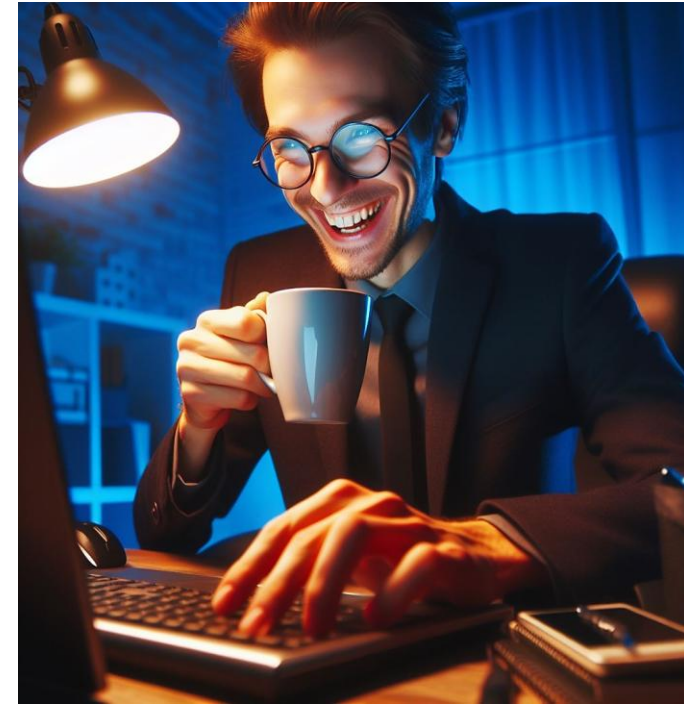


Universidad de Oviedo

SOLO INFILTRARSE NO ES SUFICIENTE... (LA MAYORÍA DE LAS VECES)



- **Obtener el acceso inicial y ejecutar nuestro código en un sistema comprometido es el primer paso de ataque**
 - Reconocimiento, provisión de **recursos**, **acceso inicial** y (finalmente) ejecución de código personalizado para la **explotación** (**Tema 6**)
- **Las posibilidades del código que ejecutemos son limitadas**
 - *¿Por qué? ¿Qué limita lo que puede hacer el código?*
- *¿Cómo se puede evitar eso? ¡Poder ilimitado! 😊*
- **Hablaremos de algunas técnicas de cada táctica**
 - **Pero recuerda: Hay muchas más en cada una de ellas**
 - ¡Y aparecen más con el tiempo!(surgen nuevas técnicas)
 - ¡MITRE ATTACK es tu "enciclopedia de ataques"!





TA0003. Persistence

Mantener la intrusión sin necesidad de volver a ganar el acceso a la víctima



TA0003. PERSISTENCE

<https://attack.mitre.org/tactics/TA0003/>



- Técnicas que los adversarios utilizan para **mantener el acceso ("mantener un punto de apoyo o foothold") a sistemas / redes comprometidos**
 - Así que no tienes que ejecutar de nuevo tus TTP de Initial Access
 - El objetivo es garantizar un **acceso continuo y no autorizado** al atacante
 - El acceso se mantiene, aunque reinicien, cambien credenciales...
- Estas técnicas incluyen métodos como
 - Modificar **archivos de arranque del sistema**
 - Crear nuevas **cuentas de usuario** o modificar las existentes
 - Alterar o crear **servicios o daemons del sistema**
 - Uso de **tareas o trabajos programados** para re-ejecutar malware
 - Secuestrar **comandos de búsqueda** o **rutas de aplicación** para cargar código malicioso en lugar de programas legítimos
- Ejemplos
 - <https://github.com/swisskyrepo/PayloadsAllTheThings/blob/master/Methodology%20and%20Resources/Linux%20-%20Persistence.md>, <https://pentestlab.blog/methodologies/red-teaming/persistence/>

TTPs de TA0003. PERSISTENCE



SSI

Persistence

23 techniques

Account Manipulation (7)
BITS Jobs
Boot or Logon Autostart Execution (14)
Boot or Logon Initialization Scripts (5)
Cloud Application Integration
Compromise Host Software Binary
Create Account (3)
Create or Modify System Process (5)
Event Triggered Execution (17)
Exclusive Control
External Remote Services
Hijack Execution Flow (12)
Implant Internal Image
Modify Authentication Process (9)
Modify Registry
Office Application Startup (5)
Power Settings
Pre-OS Boot (5)
Scheduled Task/Job (5)
Server Software Component (6)
Software Extensions (2)
Traffic Signaling (2)
Valid Accounts (4)

● El MITRE ATT&CK tiene muchas TTP de persistencia

- La 2ª táctica con más técnicas (¡solo por debajo de Defense Evasion!)

● Entre ellos podemos destacar

- **Crea nuevas cuentas de usuario.** Ejs.:
 - **Cuentas de servicio (Tema 4)**, pero modificadas para permitir inicios de sesión interactivos
 - Nuevas cuentas con **IDs de usuario "sigilosos"**
 - Nuevas cuentas con privilegios de **administrador** (UID = 0 en Linux)
- **Puertas traseras (backdoors).** Ejs.:
 - Reverse shells lanzados en **scripts de inicio**
 - Reverse shells lanzados con **tareas programadas**



TA0004. Privilege Escalation

Hacerte root para “esclavizar” a la máquina víctima



TA0004. PRIVILEGE ESCALATION

<https://attack.mitre.org/tactics/TA0004/>



- **Técnicas utilizadas para **obtener permisos de nivel superior** en un sistema o red**
 - Ej.: Pasar de un usuario estándar a uno con derechos administrativos o a nivel de sistema
- **Los enfoques comunes pueden ser...**
 - **Abuso del mecanismo para adquirir privilegios elevados** de una aplicación/SO (Ej.: **sudo**)
 - Abusar de **programas que tienen el bit SUID activo**
 - Explotación de **vulnerabilidades del sistema** (Ej.: errores de software, configuraciones incorrectas...)
 - Eludir **implementaciones de MAC** (**Tema 3/4**) (Ej.: **User Account Control** (UAC) en Windows)
 - **Injectar código malicioso** en procesos con privilegios mayores
 - Modificar o abusar de la **configuración de servicios** o controladores legítimos
 - **Robo o reutilización** de credenciales con privilegios altos obtenidas durante el ataque
- **Es fundamental: Más privilegios implican más posibilidades en las siguientes tácticas (**Block 2**)**
 - Para **persistencia**, **evadir defensas**, **recopilar datos sensibles**, **moverse lateralmente** por la red...

TA0004. PRIVILEGE ESCALATION. T1548. ABUSE ELEVATION CONTROL

MECHANISM: SUDO



- **sudo** da temporalmente privilegios de **root**
- Es típico tener un grupo **sudoers** cuyos miembros pueden ejecutar todo como **root**
- A veces, esta configuración es más restrictiva
 - Privilegios completos de **sudo** se dan solo a algunos usuarios
 - Otros usuarios **pueden tener privilegios para ejecutar solo un conjunto de comandos** con **sudo**
 - La imagen muestra un usuario que solo puede ejecutar **apt-get** como **sudo**
 - Los comandos permitidos a un usuario se ven con **sudo -l**
 - *¿Qué pasa si se puede engañar a los comandos para que no terminen normalmente? ¿Se pierden los derechos de **root** adquiridos temporalmente?*
 - *¿Y si pueden ser engañados para leer o escribir archivos no deseados? ¿O ejecutar procesos inesperados?*

```
GNU nano 2.9.3 /etc/sudoers
Defaults        secure_path="/usr/local/sbin:/usr/local/bin\
# Host alias specification
# User alias specification
# Cmnd alias specification
# User privilege specification
root    ALL=(ALL:ALL) ALL
# Members of the admin group may gain root privileges
%admin   ALL=(ALL) ALL
# Allow this user to execute any command
%redondo ALL=(ALL:ALL) ALL
# Allow this user to update the system only
%redondo_nosudoer ALL=/usr/bin/apt-get
```

```
redondo_nosudoer@miw:~$ sudo -l
Matching Defaults entries for redondo_nosudoer on miw:
  env_reset, mail_badpass,
  secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\
User redondo_nosudoer may run the following commands on miw:
  (root) /usr/bin/apt-get
```

TA0004. PRIVILEGE ESCALATION. T1548. ABUSE ELEVATION CONTROL

MECHANISM: PROGRAMAS SUID



- Los programas setuid y setgid son ejecutables que tienen estos bits de permiso habilitados
 - Ejecuta `chmod +s` para activar este bit en cualquier ejecutable
- Estos bits permiten que un programa se ejecute temporalmente con privilegios de **root**
 - Normalmente porque hacen algo que lo requiere
 - Para ver los ejecutables instalados actualmente con estos bits habilitados haz `find / -perm -u=s -type f 2>/dev/null`
- *¿Y si estos programas pueden ser engañados para mantener estos privilegios de root más tiempo del necesario?*

```
redondo_nosudoer@miw:~$ find / -perm -u=s -type f 2>/dev/null
/opt/VMBoxGuestAdditions-6.1.10/bin/VMBoxDRMClient
/home/redondo/python
/usr/lib/snapd/snap-confine
/usr/lib/policykit-1/polkit-agent-helper-1
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/xorg/Xorg.wrap
/usr/lib/eject/dmccrypt-get-device
/usr/lib/x86_64-linux-gnu/lxc/lxc-user-nic
/usr/lib/openssh/ssh-keysign
/usr/bin/at
/usr/bin/traceroute6.iputils
/usr/bin/chfn
/usr/bin/chsh
/usr/bin/passwd
/usr/bin/newgidmap
/usr/bin/newgrp
/usr/bin/gpasswd
/usr/bin/pkexec
/usr/bin/sudo
/usr/bin/newuidmap
/usr/bin/python2.7
/snap/core/9804/bin/mount
/snap/core/9804/bin/ping
/snap/core/9804/bin/ping6
/snap/core/9804/bin/su
/snap/core/9804/bin/umount
/snap/core/9804/usr/bin/chfn
/snap/core/9804/usr/bin/chsh
/snap/core/9804/usr/bin/gpasswd
/snap/core/9804/usr/bin/newgrp
```

TA0004. PRIVILEGE ESCALATION. T1548. ABUSE ELEVATION CONTROL MECHANISM: GTFOBINS



- Los conceptos anteriores se utilizan en técnicas GTFOBins
 - Lista de binarios de Unix que pueden ser explotados para eludir restricciones de seguridad
- **¿Cómo? Encontrando un uso alternativo (no previsto) a herramientas legítimas**
 - Este uso alternativo no causa un error, pero **facilita un ataque**, probablemente **ocultándolo**
 - Da como posible resultado **saltarse las restricciones de seguridad de una máquina**, como
 - **Escalar** privilegios o mantenerlos una vez elevados
 - **Transferir** archivos
 - Crear **bind** y **reverse shells**
 - ... *(facilitar otras tareas de post-explotación)*
 - Usarlos es típico de los CTF
- Las técnicas "Living Off the Land" (LOLBAS) son el equivalente para Windows
 - <https://lolbas-project.github.io/>
 - <https://www.tomshardware.com/news/microsoft-cisco-talos-nodersok-divergent-malware,40505.html>

T1548. ABUSE ELEVATION CONTROL MECHANISM: EJECUTABLE SUID



- Todos los ejecutables, efectos y técnicas para explotarlos están en la web del proyecto GTF0Bin
 - <https://gtfobins.github.io/>
- ¡Solo debemos seguir los pasos de la documentación del comando en esa web!
 - Localizar ejecutables de esa lista en el sistema objetivo
 - Determinar sus posibles efectos y si alguno de ellos se puede aprovechar para lo que queremos
 - Ver si alguno puede lanzarse (bit SUID, privilegios **sudo**...)
- Las siguientes imágenes muestran
 - Generar un shell **root** con un **python** con el bit SUID habilitado
 - Leer el archivo **shadow** con un **cat** con el bit SUID habilitado
 - Muestra el hash de usuarios privilegiados, que puede ser roto por fuerza bruta luego

```
redondo_nosudoer@miw:~$ python -c 'import os; os.execl("/bin/sh", "sh", "-p")'
# whoami
root
```

```
redondo_nosudoer@miw:~$ LFILE=/etc/shadow
redondo_nosudoer@miw:~$ cat "$LFILE"
root:*:18295:0:99999:7:::
daemon:*:18295:0:99999:7:::
bin:*:18295:0:99999:7:::
sys:*:18295:0:99999:7:::
sync:*:18295:0:99999:7:::
games:*:18295:0:99999:7:::
man:*:18295:0:99999:7:::
lp:*:18295:0:99999:7:::
mail:*:18295:0:99999:7:::
news:*:18295:0:99999:7:::
uucp:*:18295:0:99999:7:::
proxy:*:18295:0:99999:7:::
www-data:*:18295:0:99999:7:::
backup:*:18295:0:99999:7:::
list:*:18295:0:99999:7:::
irc:*:18295:0:99999:7:::
gnats:*:18295:0:99999:7:::
nobody:*:18295:0:99999:7:::
systemd-network:*:18295:0:99999:7:::
systemd-resolve:*:18295:0:99999:7:::
syslog:*:18295:0:99999:7:::
messagebus:*:18295:0:99999:7:::
_apt:*:18295:0:99999:7:::
lxd:*:18295:0:99999:7:::
uuid:*:18295:0:99999:7:::
dnsmasq:*:18295:0:99999:7:::
landscape:*:18295:0:99999:7:::
pollinate:*:18295:0:99999:7:::
redondo:$6$vXwqLLX4b1LT2Ktp$fZtmCuTZyDyCbXk91goWdygy0l
8451·0·99999·7·...
```

< Ir al Índice



BLOQUE 2: OPERANDO DE FORMA ENCUBIERTA

Nunca estuve aquí...



Departamento de Informática
Universidad de Oviedo



Universidad de Oviedo

¿QUÉ TE VAS A ENCONTRAR EN ESTE BLOQUE?



● En este bloque aprenderás

- Las diferentes **fases post-explotación** una vez que tienes privilegios elevados en sistemas comprometidos
- Cómo usar **GTFOBins** para **exfiltrar** información
- Las **diferentes consecuencias potenciales de una intrusión en un sistema** según el MITRE ATT&CK y su gravedad

POST-EXPLOTACIÓN COMPLETA

● Ahora tienes

- Fácil acceso al objetivo, cuando quieras
- Privilegios de root / administrador

● ¿Qué no puedes hacer con la infraestructura comprometida? 😊

● Veamos qué más tácticas documenta MITRE ATT&CK...

- Comprometiendo más endpoints
- Obtención de más información
- Dañar al propietario del sistema / infraestructura comprometida
 - ¿La mayoría de los daños (reputacional, disponibilidad...) son económicos?
- ...

● Mencionaremos algunas técnicas en cada táctica

- Pero, de nuevo, hay muchas más en cada una de ellas
 - ¡Y aparecen más con el tiempo!
- ¡MITRE ATTACK es tu "enciclopedia de ataques"!





TA0005. Defense Evasion

Técnicas para ser indetectables para las defensas de la víctima



TA0005. DEFENSE EVASION

<https://attack.mitre.org/tactics/TA0005/>



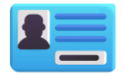
- **Técnicas que los adversarios usan para evitar ser detectados por medidas de seguridad durante sus operaciones de compromiso**
 - Ocultar sus acciones y herramientas a defensas como antimalware, XDR (**Tema 3**), firewalls (**Tema 5**), analistas...
- **Las técnicas clave de evasión defensiva incluyen**
 - **Ofuscación y anti-análisis:** Dificultar la lectura y el análisis del código malicioso (**Seminario 4**), o la detección (Ex.: cifrado (**Tema 2**), empaquetado, carga dinámica de código... (**TPP**))
 - **Eludir/degradar/desactivar el software de seguridad:** Ejemplo: Manipulación de XDR, desactivación de reglas de cortafuegos...
 - **Usar herramientas y credenciales legítimas:** Ej.: .. LOBAS/GTF0Bins...
 - **Enmascarar:** Hacer que archivos o procesos maliciosos parezcan legítimos o benignos
 - **Borrado/modificación de archivos:** Eliminación de pruebas (Ej.: logs), modificar configuraciones para cubrir huellas...
- **Esta táctica suele mezclarse con Persistence y Privilege Escalation**
 - *¿Por qué?*

TTPs de TA0005. DEFENSE EVASION



- **Defense Evasion** es la táctica con más técnicas de todas
 - *¿Por qué crees que pasa esto?*
- Entre estas técnicas podemos mencionar
 - **Ofuscación de payloads** (como los generados por **msfvenom**, **Tema 6**)
 - **Descompilar y modificar** instrucciones del programa para saltarse las protecciones integradas (**Seminario 4**)
 - Cargar código malicioso con **reflexión** (**TPP**); *¿Por qué?*
 - **Ofuscación** de archivos maliciosos

Defense Evasion 45 techniques	
ii	Abuse Elevation Control Mechanism (6)
ii	Access Token Manipulation (5)
BITS Jobs	
Build Image on Host	
Debugger Evasion	
Deobfuscate/Decode Files or Information	
Deploy Container	
Direct Volume Access	
ii	Domain or Tenant Policy Modification (2)
Email Spoofing	
ii	Execution Guardrails (2)
Exploitation for Defense Evasion	
ii	File and Directory Permissions Modification (2)
ii	Hide Artifacts (14)
ii	Hijack Execution Flow (12)
ii	Impair Defenses (11)
Impersonation	
ii	Indicator Removal (10)
Indirect Command Execution	
ii	Masquerading (11)
ii	Modify Authentication Process (9)
ii	Modify Cloud Compute Infrastructure (5)
Modify Cloud Resource Hierarchy	
Modify Registry	
ii	Modify System Image (2)
ii	Network Boundary Bridging (1)
ii	Obfuscated Files or Information (17)
Plist File Modification	
ii	Pre-OS Boot (5)
ii	Process Injection (12)
Reflective Code Loading	
Rogue Domain Controller	
Rootkit	
ii	Subvert Trust Controls (6)
ii	System Binary Proxy Execution (14)
ii	System Script Proxy Execution (2)
Template Injection	
ii	Traffic Signaling (2)
ii	Trusted Developer Utilities Proxy Execution (3)
Unused/Unsupported Cloud Regions	
ii	Use Alternate Authentication Material (4)
ii	Valid Accounts (4)
ii	Virtualization/Sandbox Evasion (3)
ii	Weaken Encryption (2)
XSL Script Processing	



TA0006. Credential Access

Obtener nuevas formas de acceder una vez dentro de un sistema



TA0006. CREDENTIAL ACCESS

<https://attack.mitre.org/tactics/TA0006/>



- **Táctica cuyo objetivo es obtener credenciales válidas (Ej.: usuarios/contraseñas)**
 - Se usan para **saltarse** la autenticación, elevar privilegios, facilitar movimientos laterales...
 - Es menos probable que **active alarmas** (Ej.: XDR, **Tema 4**) que explotar vulnerabilidades; *¿Por qué?*
 - También puede permitir el acceso a más sistemas, ser más difícil de detectar, crear más cuentas...
- **Las técnicas comunes incluyen**
 - **Fuerza bruta** (o variantes, **Tema 6**)
 - **Keylogging** (**Tema 1**)
 - **Volcado de credenciales**: Robo de credenciales (KDFs (**Tema 2**) o texto plano) de la RAM/SO
 - Ejemplo: Mimikatz extrae contraseñas del proceso LSASS en Windows
 - Ataques **Attacker-in-the-Middle** : *¿Cómo?*
 - Explotar un **almacenamiento inseguro de credenciales**; *¿Ejemplos?*
- **Estas credenciales se utilizan luego en otras tácticas posteriores a la explotación**
 - Particularmente Lateral Movement y Persistence

TTPs de TA0006. CREDENTIAL ACCESS



● Podemos destacar algunas técnicas de estas tácticas

- **Localizar e intentar acceder** a archivos donde normalmente se almacenan contraseñas, claves de API, etc.
 - *¿Cómo puedes aprovechar la fase de Reconocimiento (Tema 6) para esto?*
- Robar archivos de credenciales y **descifrarlos localmente**; *¿Por qué?*
- Comandos específicos de **Meterpreter**

Credential Access 17 techniques

Adversary-in-the-Middle (4)

Brute Force (4)

Credentials from Password Stores (6)

Exploitation for Credential Access

Forced Authentication

Forge Web Credentials (2)

Input Capture (4)

Modify Authentication Process (9)

Multi-Factor Authentication Interception

Multi-Factor Authentication Request Generation

Network Sniffing

OS Credential Dumping (8)

Steal Application Access Token

Steal or Forge Authentication Certificates

Steal or Forge Kerberos Tickets (5)

Steal Web Session Cookie

Unsecured Credentials (8)



TA0007. Discovery

Descubrir el entorno de la víctima una vez dentro de su infraestructura



TA0007. DISCOVERY

<https://attack.mitre.org/tactics/TA0007/>



- Técnicas que los adversarios utilizan para **obtener conocimiento** de la red interna y el entorno del sistema que han comprometido
 - Tras el acceso, los atacantes necesitan "**mapear**" el **entorno** para identificar sus próximos objetivos
 - Localizar datos sensibles y encontrar rutas para el movimiento lateral y la escalada de privilegios...
 - Esta recopilación de información es necesaria para planificar el resto del ataque (y sus limitaciones)
- Técnicas comunes incluyen
 - **Descubrimiento de información del sistema:** Recopilación de detalles básicos sobre el host
 - Versión del SO, hardware, procesos en ejecución, cuentas de usuario...
 - **Descubrimiento de servicios de red:** Escaneo de la red o del sistema local
 - Para identificar servicios en ejecución, puertos abiertos, detalles de configuración...
 - **Descubrimiento de elementos compartidos en red:** Identificación de archivos compartidos y carpetas compartidas accesibles
 - Puede haber datos o documentos sensibles allí, sin securizar; *¿Por qué?*
 - **Descubrimiento de cuentas:** Listar cuentas locales y de dominio, grupos y permisos
 - Identificar objetivos de alto valor
 - **Descubrimiento remoto de sistemas:** Identificación de otros puntos finales accesibles en la red

TTPs DE TA0007. DISCOVERY



SSI

Discovery
33 techniques

- Los adversarios suelen aprovechar herramientas nativas del SO para su descubrimiento, lo que dificulta su detección
 - Como LOLBAS/GTF0Bins, pero sin "uso creativo" 😊
 - Ej.: **ipconfig**, **whoami**, **net view**, **tasklist**, **arp**...
 - Depende de la información que necesiten saber
- Además, si se instalan (o se pueden instalar de forma sigilosa), también pueden usar herramientas especializadas de descubrimiento
 - Como **nmap** (**Tema 6**)
 - En general, las herramientas de Reconnaissance también son útiles en esta fase

II Account Discovery (4)
Application Window Discovery
Browser Information Discovery
Cloud Infrastructure Discovery
Cloud Service Dashboard
Cloud Service Discovery
Cloud Storage Object Discovery
Container and Resource Discovery
Debugger Evasion
Device Driver Discovery
Domain Trust Discovery
File and Directory Discovery
Group Policy Discovery
Log Enumeration
Network Service Discovery
Network Share Discovery
Network Sniffing
Password Policy Discovery
Peripheral Device Discovery
II Permission Groups Discovery (3)
Process Discovery
Query Registry
Remote System Discovery
II Software Discovery (1)
System Information Discovery
II System Location Discovery (1)
II System Network Configuration Discovery (2)
System Network Connections Discovery
System Owner/User Discovery
System Service Discovery
System Time Discovery
Virtual Machine Discovery
II Virtualization/Sandbox Evasion (3)



TA0008. Lateral Movement

"Saltar" a través de la infraestructura de la víctima



TA0008. LATERAL MOVEMENT

<https://attack.mitre.org/tactics/TA0008/>



- **Técnicas que los adversarios utilizan para navegar y acceder a otros sistemas dentro de una red comprometida**
 - Pasar del huésped inicialmente vulnerado a otros **objetivos de mayor valor**
 - **Ejemplo:** Un Controlador de Dominio (**ASR**), un servidor con datos sensibles...
- **Las técnicas comunes incluyen**
 - **Servicios remotos:** Uso de herramientas legítimas de administración remota (RATs) para iniciar sesión en otros sistemas usando credenciales robadas
 - Ex.: RDP, SSH, VNC, PsExec... *¿Recuerdas la estafa de Microsoft?*
 - **Spear phishing interno:** Enviar correos desde una cuenta interna comprometida para engañar a otros empleados y que ejecuten código malicioso
 - Estos tienden a ser más efectivos que el spear phishing "normal"; *¿Por qué?*
 - **Explotar servicios remotos:** Explotar vulnerabilidades en servicios (Ej.: SMB, RDP...) en otros hosts
 - **Pass the Hash (PtH) / Pass the Ticket (PtT):** Reutilizar hashes de contraseñas robadas o tickets de Kerberos (protocolo de autenticación muy popular) para autenticar a otras máquinas
 - ¡Sin necesitar la contraseña en texto plano!

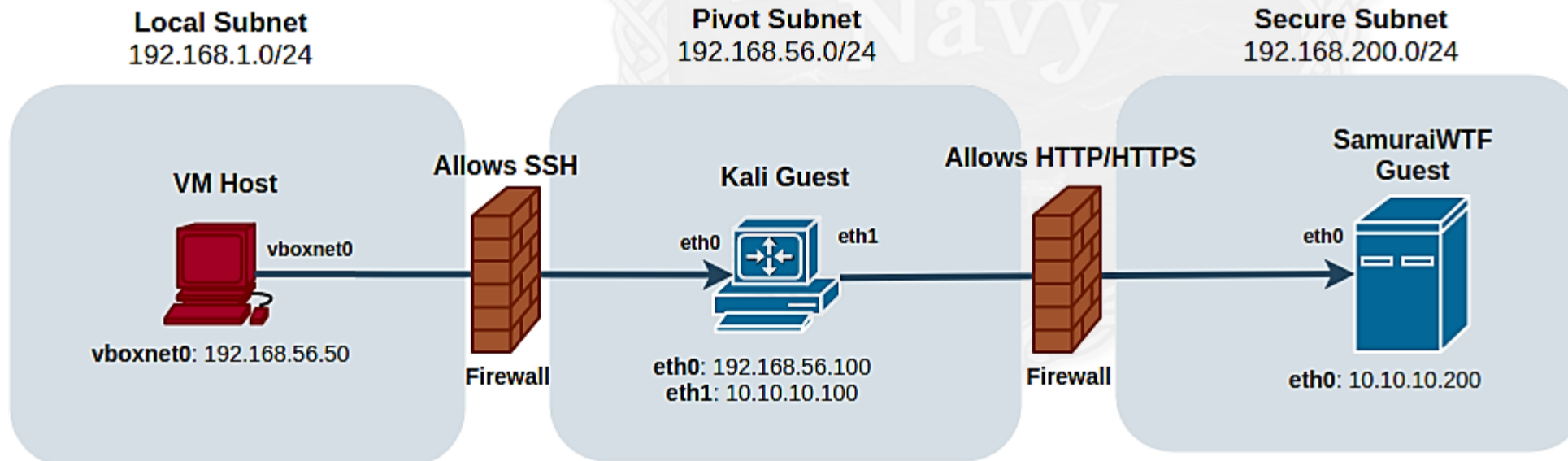
LATERAL MOVEMENT VS PIVOTING

- Son conceptos estrechamente relacionados
- El pivoting es una técnica a nivel de red (cómo) que **permite** Lateral Movement (qué)
 - Un atacante compromete el Host A (Ej.: un servidor web en una DMZ, **Tema 5**)
 - El Host A es la **única máquina** que puede "ver" la red privada DMZ (**Tema 5**)
 - El atacante **establece un pivote** a través del Host A
 - Ex.: Un túnel SSH cifrado
 - El atacante ahora puede usar herramientas y técnicas para realizar **Lateral Movement** contra hosts internos
 - No se puede acceder directamente desde internet
 - Pero ahora el servidor web lo permite, "pivotando" a través de él

Concepto	Definición	Enfoque principal
Lateral Movement (<i>Táctica MITRE ATT&CK</i>)	La acción de moverse de un host a otro en la red usando diversas técnicas	Técnicas y objetivo (ampliando el acceso)
Pivoting (<i>Técnica de red</i>)	El método de redirigir el tráfico de red a través de un host comprometido para acceder a redes internas que de otro modo serían inalcanzables	Infraestructura de red y acceso (bypass de firewalls)

TTPs DE TA0008. LATERAL MOVEMENT

- Entre las técnicas que podemos destacar, podemos encontrar
 - Comprometer las credenciales RDP
 - Túneles SSH (**Tema 2**) (<https://deephacking.tech/pivoting-con-ssh/>)



Lateral Movement

9 techniques

- Exploitation of Remote Services
- Internal Spearphishing
- Lateral Tool Transfer
- Remote Service Session Hijacking (2)
- Remote Services (8)
- Replication Through Removable Media
- Software Deployment Tools
- Taint Shared Content
- Use Alternate Authentication Material (4)



TA0009. Collection

Recopilar información de la víctima una vez dentro de su infraestructura



TA0009. COLLECTION

<https://attack.mitre.org/tactics/TA0009/>



- **Técnicas que los adversarios usan para identificar y recopilar los datos objetivo que buscan en un sistema o red comprometido, antes de moverlos fuera de la red**
 - Documentos, BBDD, archivos de email, pulsaciones de teclas, configuración del sistema...
 - Por tanto, es la táctica "natural" (y necesaria) **anterior** de la de Exfiltration (siguiente sección 😊)
 - Sus técnicas se centran en **encontrar** y **preparar** (para ser exfiltrada) la información deseada
- **Las técnicas comunes incluyen**
 - **Datos del sistema local:** Búsqueda y recopilación de archivos y carpetas en el sistema actualmente accedido que contienen información sensible
 - Ej.: Navegar por directorios de usuarios, archivos temporales, historial de navegador...
 - **Datos del portapapeles:** Captura de información que los usuarios copian y pegan
 - **Captura de entradas:** Grabación de la actividad del usuario mediante keylogging o captura de pantalla
 - **Datos de unidades compartidas en red:** Datos críticos de la organización se suelen almacenar ahí
 - **Recolección automatizada:** Uso de scripts o herramientas automatizadas para buscar y recopilar datos a lo largo del tiempo

TTPs DE TA0009. COLLECTION



- Tras recopilar datos con éxito, se ejecutan técnicas de **staging**
 - **Comprimir, cifrar o empaquetar** los datos recogidos en una única ubicación del host comprometido
 - Cualquier cosa que facilite la preparación para la exfiltración
 - O esconderlo a simple vista (**esteganografía**, **Tema 2**)
- Podemos destacar estas técnicas
 - **Las cookies con IDs de sesión** activos son muy valiosas: el inicio de sesión evita la MFA
 - **Los archivos personales de los usuarios** pueden tener contraseñas en texto plano o datos sensibles que pueden llevarte a recopilar más información 😊
 - **Meterpreter** dispone de herramientas adecuadas para esta fase

Collection	
17 techniques	
Adversary-in-the-Middle (4)	
Archive Collected Data (3)	
Audio Capture	
Automated Collection	
Browser Session Hijacking	
Clipboard Data	
Data from Cloud Storage	
Data from Configuration Repository (2)	
Data from Information Repositories (5)	
Data from Local System	
Data from Network Shared Drive	
Data from Removable Media	
Data Staged (2)	
Email Collection (3)	
Input Capture (4)	
Screen Capture	
Video Capture	



TA0011. Command and Control

Controlar y dar órdenes a las máquinas de la víctima a distancia



TA0011. COMMAND AND CONTROL (AKA C2)

<https://attack.mitre.org/tactics/TA0011/>



- **Técnicas que los adversarios usan para comunicarse (y mantener el contacto) con sistemas comprometidos (los "bots" o "implantes") dentro de la red de la víctima**
 - C2 es el **canal de comunicación remoto** que permite al atacante enviar nuevas instrucciones, subir herramientas, recibir datos recopilados del malware que se ejecuta dentro de la red...
 - Un canal de comunicación **encubierto, resiliente e interactivo** con los sistemas comprometidos durante **toda la fase de post-explotación**
- **Técnicas comunes incluyen**
 - **Protocolos estándar:** (Ej.: HTTP, HTTPS o DNS) mezclando tráfico malicioso con el normal; *¿Por qué?*
 - **Protocolos no estándar:** Menos conocidos o personalizados sobre puertos estándar; *¿Por qué?*
 - **Codificación/ofuscación de datos:** En la comunicación (**Tema 2**) para ocultar operaciones
 - **Túneles:** Crear túneles (como VPNs o SSH) para enrutar de forma segura el tráfico C2 fuera de la red
 - *¿Cuáles son las ventajas de este método?*
 - **Uso de servicios legítimos:** Uso de servicios externos de confianza para la comunicación C2
 - Plataformas de redes sociales, correo electrónico, almacenamiento en la nube... *¿Por qué?*

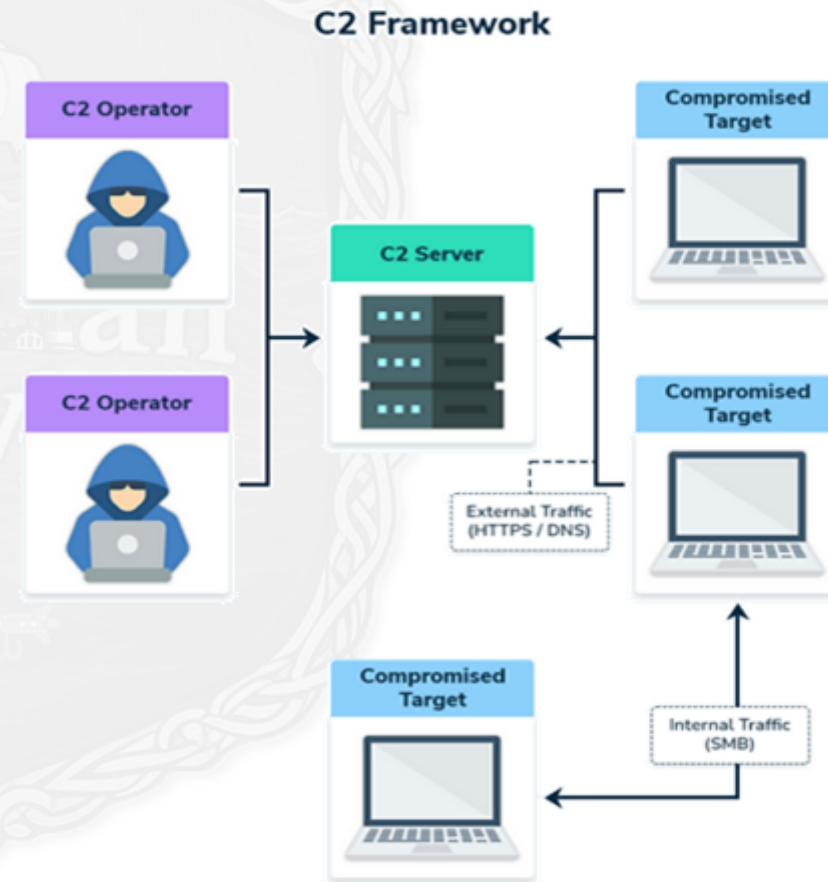
TTPs DE TA0011. COMMAND AND CONTROL

Command and Control 18 techniques

Application Layer Protocol (5)
Communication Through Removable Media
Content Injection
Data Encoding (2)
Data Obfuscation (3)
Dynamic Resolution (3)
Encrypted Channel (2)
Fallback Channels
Hide Infrastructure
Ingress Tool Transfer
Multi-Stage Channels
Non-Application Layer Protocol
Non-Standard Port
Protocol Tunneling
Proxy (4)
Remote Access Tools (3)
Traffic Signaling (2)
Web Service (3)

Entre estas técnicas podemos mencionar

- Usar **frameworks C2 personalizados** (Ej.: Cobalt Strike, Slither...)
- Usar **RATs legítimos** para convertir endpoints en “marionetas”
- **Botnets**: Hacer que un sistema comprometido forme parte de una botnet
 - Para lanzar campañas coordinadas
 - DDoS, spam, phishing...
- Características de **Meterpreter**



Distribución típica de una infraestructura C2.

Fuente: <https://medium.com/@redfanatic7/what-is-c2-framework-installation-guide-0710a431a801>



TA0010. Exfiltration

Extraer los datos recogidos de la víctima sin ser detectado



TA0010. EXFILTRATION

<https://attack.mitre.org/tactics/TA0010/>



● Técnicas que los adversarios usan para **robar datos** de una red comprometida

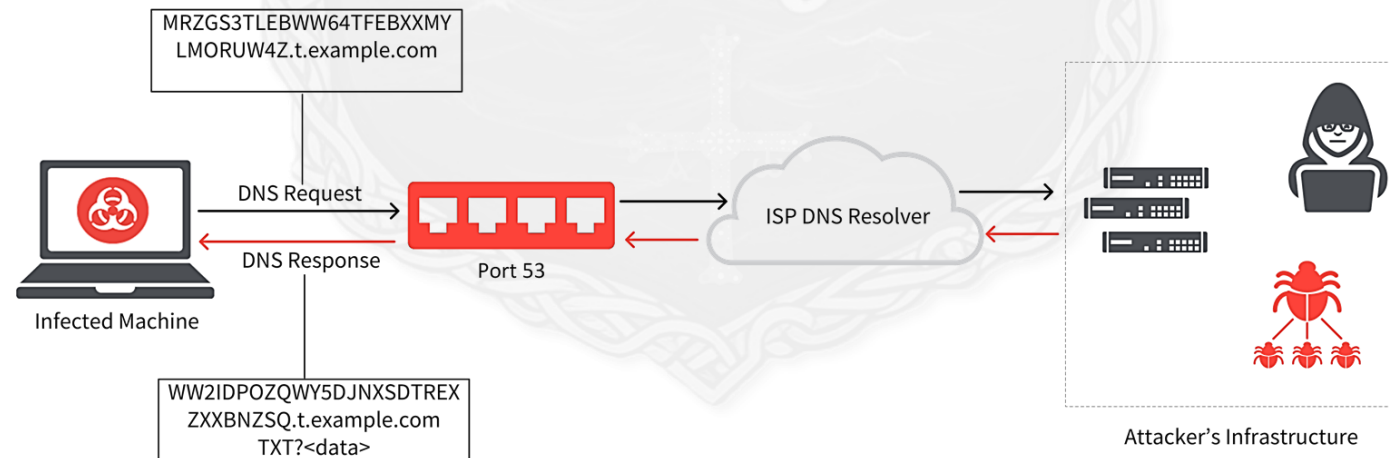
- Transfiriéndolos a una ubicación externa **bajo su control**
- Su objetivo es mover **sigilosamente** datos sensibles fuera del entorno de la víctima, a menudo **evitando la monitorización de red y los controles de seguridad**

● Las técnicas comunes incluyen

- **Exfiltración sobre canal C2:** Creada en una fase anterior
- **Exfiltración sobre protocolo alternativo:** Transferencia de datos usando un protocolo inusual o no C2
 - Ej.: Túneles DNS, FTP, un protocolo cifrado completamente diferente... a un servidor externo alternativo
- **Dividir los datos exfiltrados** en pequeños fragmentos o limitar el tamaño de los paquetes
 - El enfoque "low and slow" evita alertas (IDS, **Tema 5**) por transferencias de datos grandes o repentinas
- **Exfiltración sobre medio físico:** Típica de entornos altamente seguros (o "air-gapped")
 - Ejemplo: Transferencia de datos a un dispositivo físico (Ej.: unidades USB/discos duros)
- **Exfiltración a almacenamiento en nube:** Subir los archivos robados a un servicio en la nube legítimo, pero controlado por atacantes, en el que la red de la organización **ya confía**
 - Ej.: Dropbox, Google Drive, OneDrive...

TTPs DE TA0010. EXFILTRATION

- La exfiltración requiere transmisiones eficientes e indetectables
 - Antes de la exfiltración, los datos suelen comprimirse, codificarse o cifrarse (**Tema 2**)
- De estas técnicas podemos destacar
 - Aplicaciones de los GTFOBins
 - **Túneles SSH** improvisados (Ex.: **ngrok**, **cloudflared**...)
 - Servidores web improvisados "hit and run" (Ej.: con Python)



Exigir indetectabilidad da lugar a usar técnicas muy imaginativas, como nombres DNS aleatorios (pero legales) para servidores de exfiltración. Fuente: <https://help.zscaler.com/zia/detecting-and-controlling-dns-tunnels>

Exfiltration

9 techniques

II	Automated Exfiltration (1)
	Data Transfer Size Limits
II	Exfiltration Over Alternative Protocol (3)
	Exfiltration Over C2 Channel
II	Exfiltration Over Other Network Medium (1)
II	Exfiltration Over Physical Medium (1)
II	Exfiltration Over Web Service (4)
	Scheduled Transfer
	Transfer Data to Cloud Account



TA0040. Impact

Causar daños de distinto tipo a la víctima



TA0040. IMPACT

<https://attack.mitre.org/tactics/TA0040/>



● Técnicas que los adversarios usan para manipular, interrumpir o destruir sistemas y datos con el fin de lograr su objetivo final malicioso

- Esta táctica representa la **etapa final** en la que el atacante ejecuta directamente acciones que resultan en un **daño visible o una interrupción** a la organización víctima
- Es lo que **normalmente se ve en las noticias** (¡ya es tarde para hacer algo al respecto!)

● Las técnicas comunes incluyen

- **Cifrar datos para causar impacto:** Técnica central de los ataques de ransomware
- **Destrucción de datos:** Destruir/eliminar archivos, logs o el SO; *¿Por qué? ¿Destruir es borrar?*
- **Apagado de servicios/sistemas:** Desactivar deliberadamente servicios críticos de red, MVs o apagar hosts para causar una **denegación de servicio (DoS)** o **interrupciones operativas**
- **Inhibir la recuperación del sistema:** Interrumpir o eliminar backups, volume shadow copies u otros mecanismos de recuperación para no poder restaurar fácilmente los sistemas tras el ataque
 - Se combina de forma natural con ransomware; *¿Por qué?*
- **Secuestro de recursos:** Abuso de los recursos computacionales en beneficio del atacante
 - Típico del **criptojacking**, donde los sistemas se usan para minar criptomonedas; *¿Por qué?*

TTPs DE TA0040. IMPACT

● La táctica de Impacto es un diferenciador clave de los ataques centrados únicamente en el espionaje

- Se centra en causar daños directos, inmediatos y medibles.
- Interrumpir **disponibilidad** y/o comprometer **integridad / confidencialidad** (CIA, **Tema 2**)

● Manipulando procesos empresariales / operativos, como

- Eliminación de acceso a cuentas legítimas (**pérdida de disponibilidad**)
- Destrucción de datos (**pérdida de disponibilidad/integridad**)
- Cifrado de datos (**pérdida de confidencialidad/disponibilidad/integridad**)
 - Normalmente, los ransomwares exfiltran datos antes de cifrarlos
- Manipulación de datos (almacenados, mientras se transmiten, en tiempo de ejecución...) (**pérdida de confidencialidad/integridad**)
 - Si se manipulan datos, los atacantes pueden robarlos 1º, por lo que se pierde confidencialidad
- Defacement de aplicaciones web y similares (**intimidación, pérdida de reputación**)
- Borrado de disco (destrucción masiva de datos) (**pérdida de disponibilidad/integridad**)
- Denegación de servicio en endpoints/red (**pérdida de disponibilidad**)
- Parada de servicio/sistema (**pérdida de disponibilidad**)

Impact	
15 techniques	
Account Access Removal	
II Data Destruction (1)	
Data Encrypted for Impact	
II Data Manipulation (2)	
II Defacement (2)	
II Disk Wipe (2)	
Email Bombing	
II Endpoint Denial of Service (4)	
Financial Theft	
Firmware Corruption	
Inhibit System Recovery	
II Network Denial of Service (2)	
II Resource Hijacking (4)	
Service Stop	
System Shutdown/Reboot	

¿CREES QUE LO HAS ENTENDIDO TODO? ¡AUTOEVALÚATE!



● Eres capaz de entender lo siguiente

- *Cuáles son los objetivos generales de las técnicas de Persistence*
- *Cuáles son los objetivos generales de las técnicas de Privilege Escalation*
- *Qué son los GTFOBins y cómo aprovecharlos en combinación con los mecanismos de **sudo** y bit SUID*
- *Cuáles son los objetivos generales de las técnicas de Defense Evasion*
- *Cuáles son los objetivos generales de las técnicas de Credential Access*
- *Cuáles son los objetivos generales de las técnicas de Discovery*
- *Cuáles son los objetivos generales de las técnicas de Lateral Movement*
- *Cuáles son los objetivos generales de las técnicas de Collection*
- *Cuáles son los objetivos generales de las técnicas de Impact y su capacidad para vulnerar la CIA de un sistema*

¡Muchísimas gracias!

¿Es éste el
comienzo de tu
carrera en
ciberseguridad?



Fuente : @creative_vanesa

(https://www.instagram.com/creative_vanesa/?hl=es)





TEMA 7

INTRODUCCIÓN A TÉCNICAS DE RED TEAM. TTPS 5-14



Departamento de Informática
Universidad de Oviedo



Universidad de Oviedo